The Greenholt Phish — SOC Level 1 Lab Report

Corrected Evidence Alignment

TryHackMe • SOC Level 1 • Phishing Email Investigation | Case type: Suspected phishing / malicious email attachment | Assessment: Malicious — high confidence | Environment: TryHackMe training lab

> **Note on this revision:** The original uploaded report's Appendix A had several screenshots placed under the wrong captions (a duplicate badge image sat where the WHOIS lookup should be, and everything after it was shifted out of order). This version re-matches every image to the caption it actually belongs to — see Section 10 for the corrected register, and the README at the end for a summary of what changed.

---

1. Executive Summary

The TryHackMe screenshots show an unexpected email claiming a SWIFT funds transfer was completed, referencing a payment receipt attachment. The message uses a generic greeting, a sender identity that needs independent verification, a Reply-To that routes to a different address, and an originating IP that fails the domain's SPF check. The attachment is named to suggest a PDF, but VirusTotal identifies it as a RAR archive, with 48 of 63 vendors flagging it malicious.

Conclusion: the message is a phishing lure built around financial urgency, intended to get the recipient to open an unsolicited attachment. The evidence supports classifying the email and attachment as malicious. It does **not** prove that a recipient opened the archive, that code executed, or that funds/credentials were actually stolen.

---

2. Scope, Sources, and Method

- **Scope:** the supplied Greenholt Phish challenge email and the artifacts visible in the lab screenshots.
- **Evidence used:** Thunderbird message + source/header view, WHOIS result, SPF/DMARC lookups, VirusTotal result, completed TryHackMe badge.

- **Method:** inspect message content and headers → compare From vs Reply-To → identify originating IP → check SPF/DMARC → extract attachment name and SHA-256 → verify file reputation and true file type → derive response and mitigation steps.

Limitations: this report relies on the supplied screenshots; the original `.eml` and attachment were not independently re-analyzed here. WHOIS/DNS data reflects the time of those lookups and may since have changed. A high vendor-detection ratio is strong supporting evidence, not standalone proof of execution or impact.

---

3. Observed Indicators

Artifact	Observed value	Security relevance
Subject / reference	Transfer Reference Number: 09674321	Financial-transfer theme creates urgency/legitimacy
Display name	Mr. James Jackson	Display names are trivially spoofed
From address	`info@mutawamarine.com`	Must be validated against headers and authentication results
Reply-To	`info.mutawamarine@mail.com`	Different domain — may divert replies away from the claimed sender
Originating IP	`192.119.71.157`	Associated with Hostwinds/HostPapa hosting infrastructure
SPF record	`v=spf1 include:spf.protection.outlook.com -all`	`-all` hard-fails any unauthorized sender
Authentication result	SPF: fail	Sending host was not authorized by the published SPF policy
DMARC record	`v=DMARC1; p=quarantine; fo=1`	Requests quarantine for messages failing DMARC alignment
Attachment name	`SWT_#09674321____PDF__.CAB`	Named to imply a payment/PDF document; misleading extension
SHA-256	`2e91c533615a9bb8929ac4bb76707b2444597ce063d84a4b33525e25074fff3f`	Stable indicator for blocking/correlation

Artifact	Observed value	Security relevance
File intelligence	400.26 KB; actual type RAR; 48/63 detections	Strong evidence of a malicious archive

---

4. Findings

Finding 01 — Suspicious financial-transfer pretext

Assessment: High — phishing indicator The message claims funds were transferred by SWIFT, cites a transfer reference, and says a receipt is attached, using a generic greeting for an unexpected transaction. **Mitigation:** Treat unexpected payment notices as untrusted; verify transactions through a known phone number or approved finance workflow, never contact details from the message itself.

Finding 02 — From / Reply-To mismatch

Assessment: High — identity / reply-redirection indicator From is `info@mutawamarine.com`; Reply-To is `info.mutawamarine@mail.com` — a reply would go to a different domain than the claimed sender. **Mitigation:** Gateway rules should flag external Reply-To mismatches and unexpected free-mail reply addresses. Train users to report rather than reply.

Finding 03 — Originating IP and sender infrastructure

Assessment: Medium/High — suspicious origin The originating IP `192.119.71.157` resolves to Hostwinds/HostPapa hosting infrastructure. Hosting-provider infrastructure is not inherently malicious — its significance here comes from the SPF mismatch and the broader indicator set. **Mitigation:** Use sender authentication and threat-intel context rather than blanket-blocking a hosting provider; block the specific indicator where justified.

Finding 04 — SPF authentication failure

Assessment: High — authentication failure The domain's SPF record ends in `-all` (hard fail), and the message source shows SPF: fail — the sending host was not authorized. **Mitigation:** Ensure the receiving gateway evaluates SPF/DKIM/DMARC and quarantines or rejects per policy.

Finding 05 — DMARC policy and alignment

Assessment: High when combined with SPF failure The published policy is `p=quarantine`, requesting quarantine for mail failing DMARC evaluation. The DNS record alone doesn't prove the receiver actually quarantined this specific message. **Mitigation:** Enforce DMARC at the gateway; review aggregate reports; move toward quarantine/reject once legitimate senders are correctly configured.

Finding 06 — Misleading attachment name vs. actual file type

Assessment: Critical — malicious attachment indicator The attachment is named `SWT_#09674321____PDF__.CAB` but VirusTotal reports the actual type as RAR. A disguised filename encourages opening and may mask the payload. **Mitigation:** Block/quarantine by hash, block risky archive types from untrusted senders, sandbox-detonate, inspect only in isolated environments.

Finding 07 — Malicious file reputation

Assessment: Critical — 48/63 detections 48 of 63 vendors flag the SHA-256 as malicious. Multiple independent detections strongly support treating the sample as malicious, though the ratio alone doesn't show it was executed in a victim environment. **Mitigation:** Add the hash to EDR/AV blocklists; search mailbox and endpoint telemetry for the hash and filename; investigate any delivery/execution events.

---

5. Likely Attack Narrative

1. The sender crafted a message around a purported SWIFT payment and transfer reference to look business-related.
2. The visible From identity (`info@mutawamarine.com`) differed from the Reply-To (`info.mutawamarine@mail.com`), letting replies be routed to a different mailbox.
3. The message originated from `192.119.71.157` and failed SPF against a policy authorizing only Microsoft's protection service.
4. The email encouraged opening an unsolicited "receipt" attachment named to imply a PDF, but threat intelligence identified it as a RAR archive with 48/63 detections.
5. The likely objective was to get the recipient to open/extract the archive, risking malware execution or a follow-on social-engineering step.

Boundary: the evidence does not reveal the archive's contents, payload behavior, C2 infrastructure, or whether anyone actually opened it — those should not be asserted without further forensic evidence.

---

6. MITRE ATT&CK Mapping (Tentative)

Technique	Why it may apply	Confidence
T1566.001 — Spearphishing Attachment	Unsolicited attachment used as the lure	High for delivery method
T1036 — Masquerading	Filename implies PDF; actual type is RAR	Moderate — naming observed, intent inferred
T1204.002 — User Execution: Malicious File	Would apply if the archive's contents were opened/executed	Not confirmed — no execution evidence

---

7. Mitigation and Detection Plan

Immediate response (if this were a live incident):

- Quarantine the email org-wide; preserve the original `.eml`, headers, and attachment metadata.
- Hunt across email, proxy, DNS, EDR and SIEM for the sender, Reply-To, reference number, IP, filename, and SHA-256.
- Isolate any endpoint that opened the file; collect EDR evidence before remediation.
- Block the hash in EDR/AV and mail controls; avoid broad IP blocks without corroborating intel.
- If credentials were entered anywhere related, reset them and review sign-in logs — this evidence alone doesn't prove that happened.

Preventive controls:

- Enforce SPF/DKIM/DMARC evaluation with consistent quarantine/reject action.
- Flag external-sender, display-name-impersonation, and Reply-To-mismatch messages.
- Attachment sandboxing, archive inspection, file-type validation, safe-link scanning.

- Limit local admin rights; train staff to verify payment instructions out-of-band.

Suggested detection logic: correlate when an email shows two or more of — SPF/DMARC fail, Reply-To domain ≠ From domain, unexpected archive with a document-like name, hash/sender/IP matching threat intel. Tune against legitimate mail systems to cut false positives.

---

8. Evidence Checklist

Evidence item	Captured?	Preservation note
Rendered email + subject	Yes	Export original `.eml` with timestamp
From / Reply-To fields	Yes	Preserve full raw headers
Originating IP / WHOIS	Yes	Save lookup date, source, header chain
SPF and DMARC lookups	Yes	Record DNS response and time — policies can change
Attachment SHA-256 / VirusTotal	Yes	Preserve hash, size, type, detection ratio, report date
Archive contents / payload behavior	No	Only inspect in an isolated malware-analysis environment
Endpoint execution / impact	No	Check EDR, process, file, DNS, proxy, auth logs

---

9. Final Conclusion

The Greenholt Phish sample should be classified as a malicious phishing email. The strongest combined indicators are the unexpected financial-transfer story, the differing Reply-To address, the SPF failure, the misleading attachment name, and the 48/63 VirusTotal detection ratio for a file that is actually a RAR archive. The likely attack path is social engineering through a fake payment receipt, with the attachment serving as the next-stage delivery mechanism.

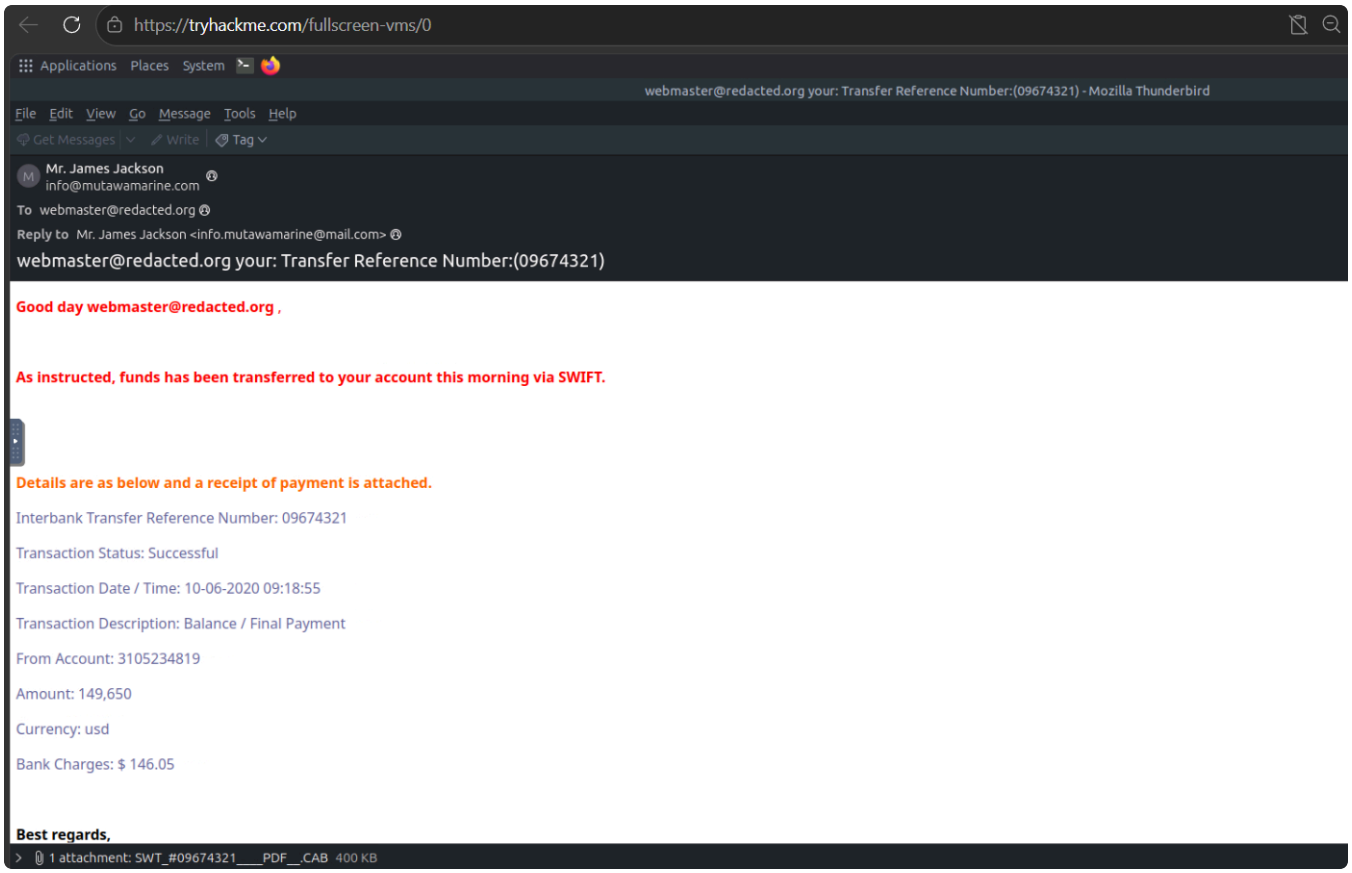
Recommended disposition: quarantine the message, block/hunt the SHA-256, search for related deliveries, and investigate endpoint telemetry if the file was accessed. Do not claim successful execution, credential theft, or financial loss without separate confirming evidence.

---

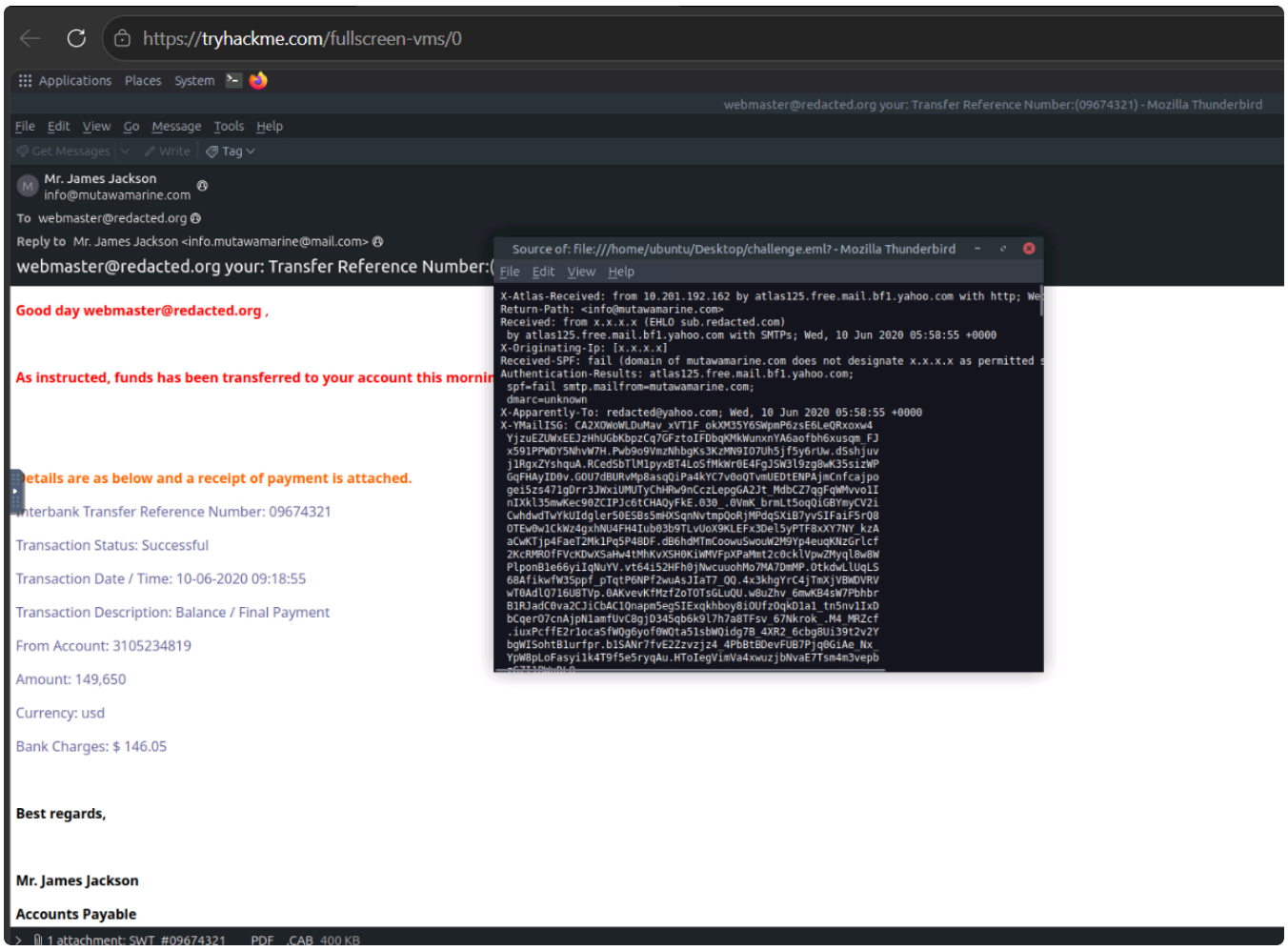
10. Appendix A — Evidence Register (Corrected)

The screenshots below are matched to the finding each one actually supports. Numbering replaces the original report's A–K letters, which had drifted out of sync with the images starting partway through (a duplicate badge screenshot had been inserted where the WHOIS lookup belonged, pushing every later image one or more slots out of place).

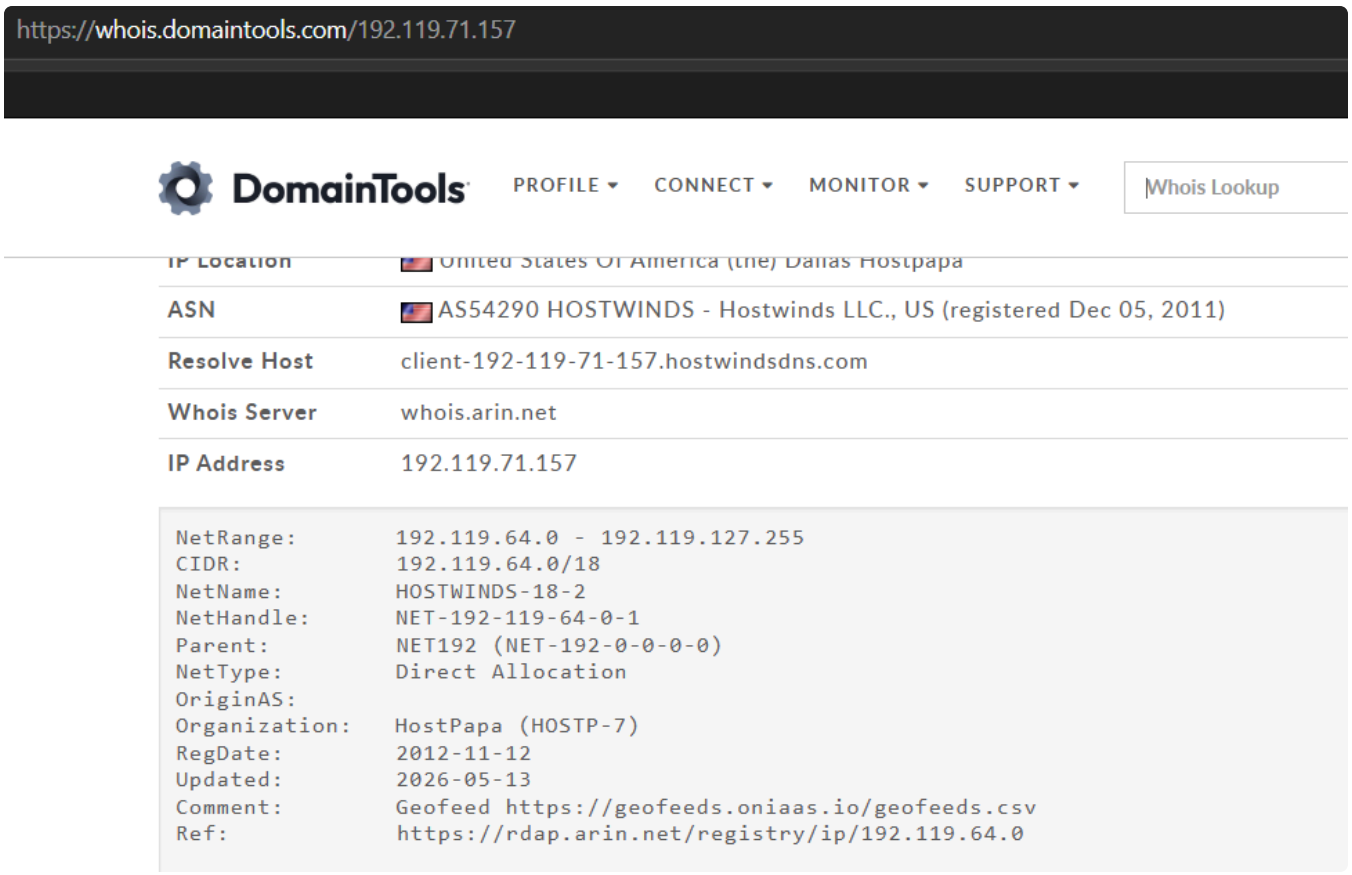
Evidence 1 — Email body, transfer pretext, and attachment (Finding 01, 06)



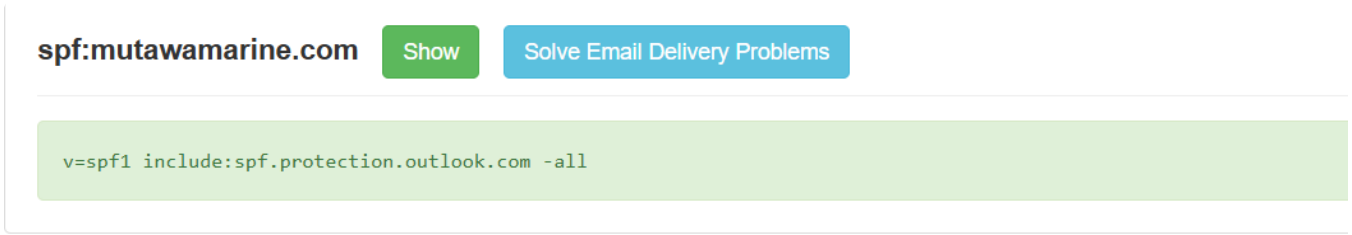
Evidence 2 — Raw message source: From / Reply-To / Authentication-Results (Finding 02, 03, 04)



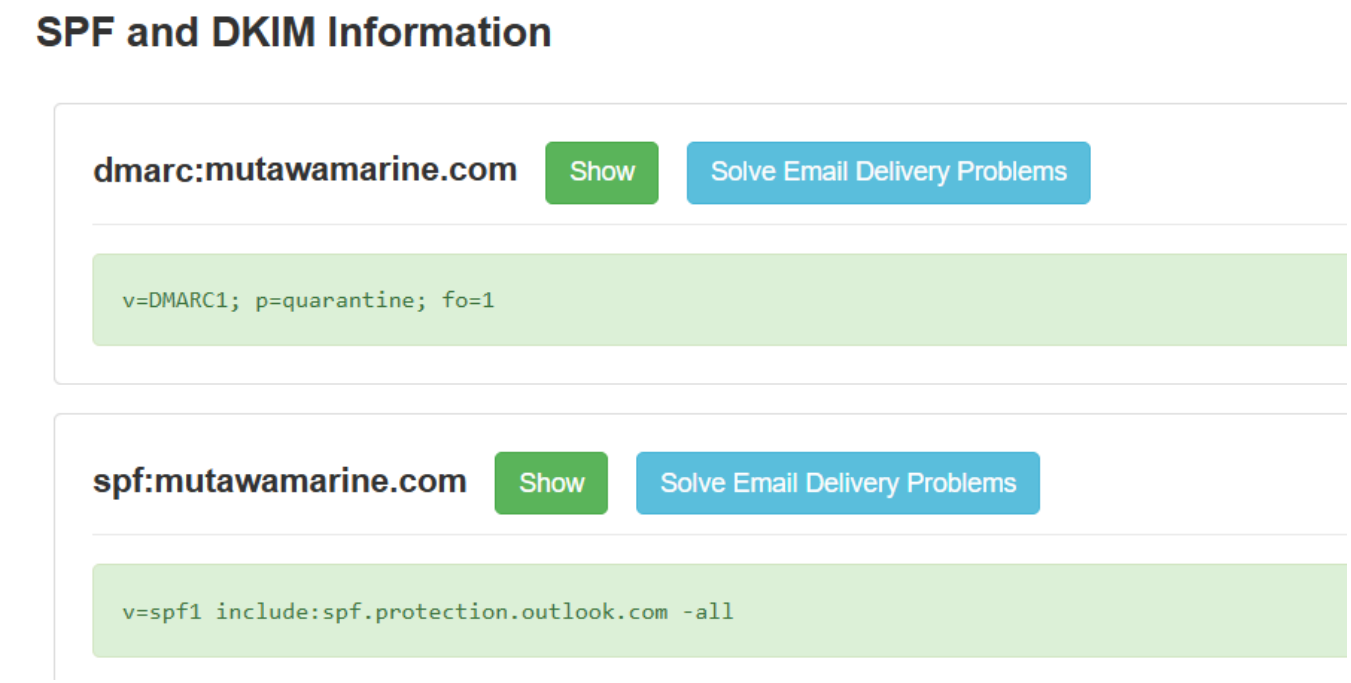
Evidence 3 — WHOIS lookup for the originating IP (Finding 03)



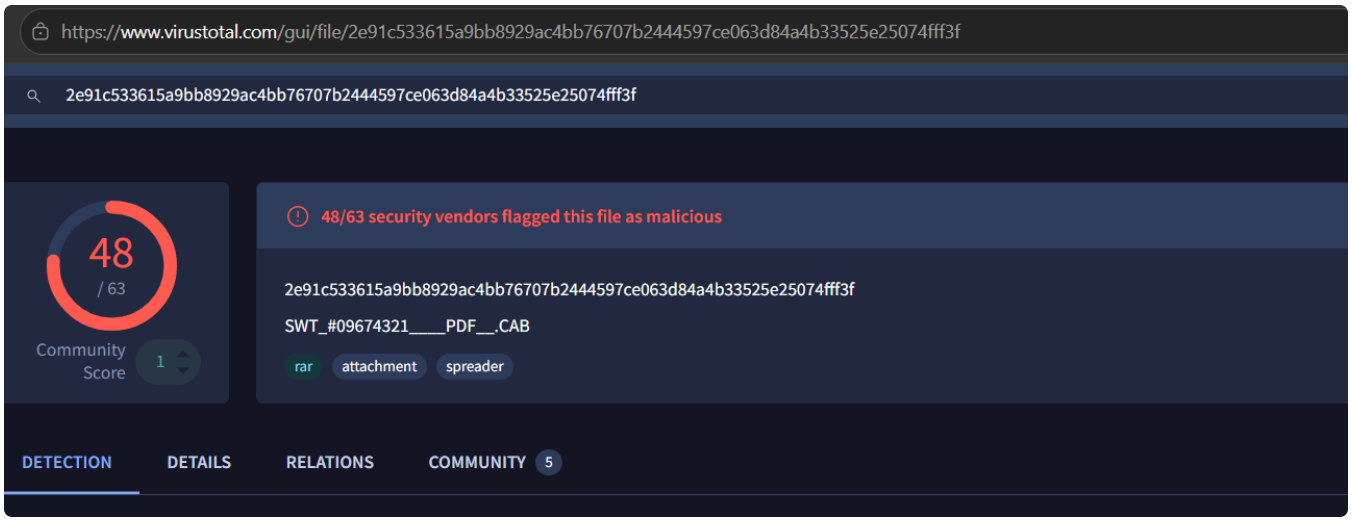
Evidence 4 — SPF record lookup (Finding 04)



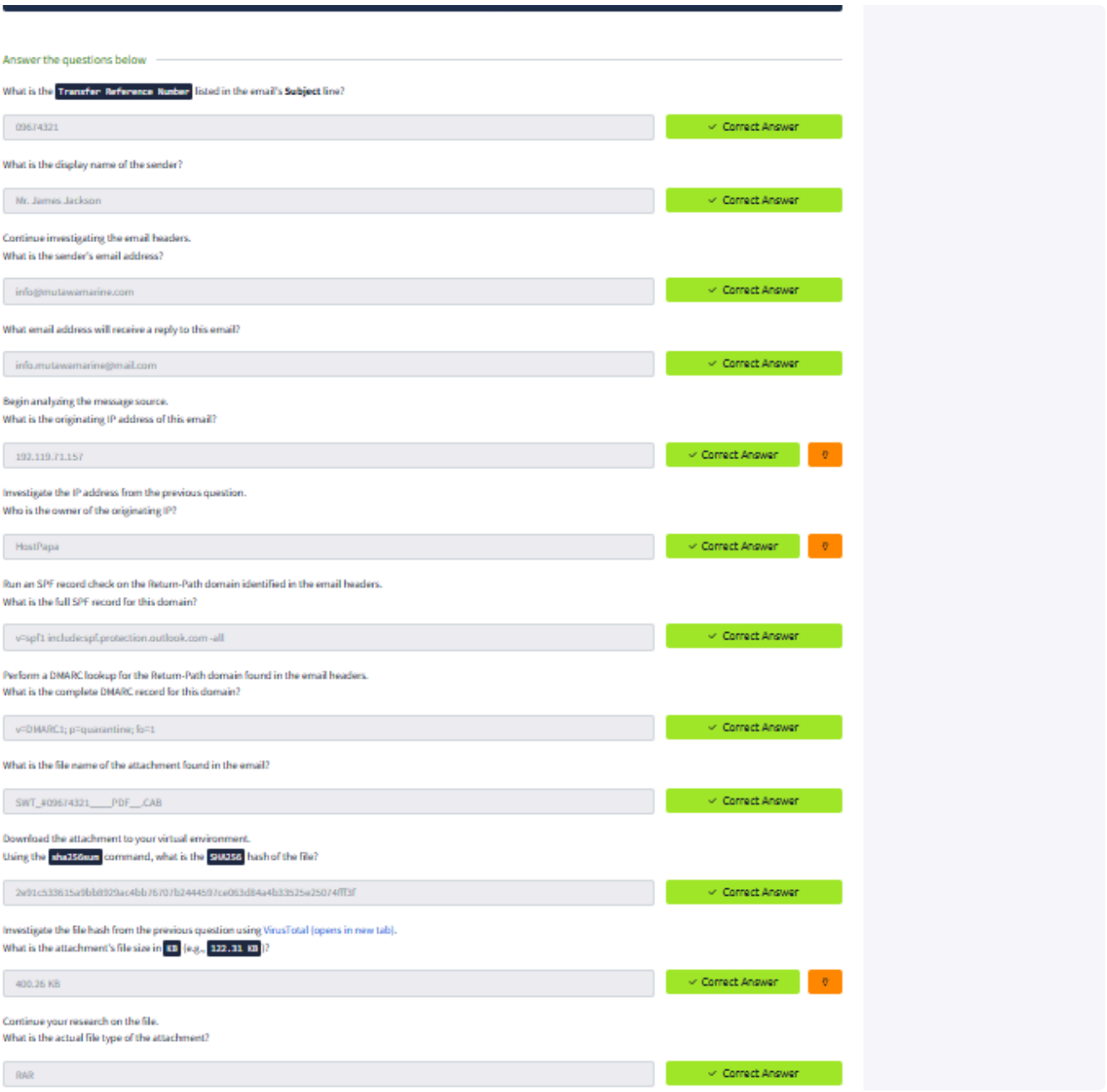
Evidence 5 — Combined DMARC + SPF record lookup (Finding 04, 05)



Evidence 6 — VirusTotal detection result (Finding 06, 07)



Evidence 7 — TryHackMe submitted answers confirming each indicator (cross-check for Findings 01–07)


Answer the questions below
What is the Transfer Reference Number listed in the email's Subject line?
03674321
Correct Answer
What is the display name of the sender?
Mr. James Jackson
Correct Answer
Continue investigating the email headers.
What is the sender's email address?
info@mutawamarine.com
Correct Answer
What email address will receive a reply to this email?
info.mutawamarine@mail.com
Correct Answer
Begin analyzing the message source.
What is the originating IP address of this email?
192.119.71.157
Correct Answer
0
Investigate the IP address from the previous question.
Who is the owner of the originating IP?
HostPapa
Correct Answer
0
Run an SPF record check on the Return-Path domain identified in the email headers.
What is the full SPF record for this domain?
v=spf1 include:spf.protection.outlook.com -all
Correct Answer
Perform a DMARC lookup for the Return-Path domain found in the email headers.
What is the complete DMARC record for this domain?
v=DMARC1; p=quarantine; fo=1
Correct Answer
What is the file name of the attachment found in the email?
SWT_#03674321____PDF__.CAB
Correct Answer
Download the attachment to your virtual environment.
Using the sha256sum command, what is the SHA256 hash of the file?
2e91c533615a9bb8929ac4bb76707b2444597ce063d84a4b33525e25074ff3f
Correct Answer
Investigate the file hash from the previous question using VirusTotal (opens in new tab).
What is the attachment's file size in KB (e.g., 122.31 KB)?
400.26 KB
Correct Answer
0
Continue your research on the file.
What is the actual file type of the attachment?
RAR
Correct Answer